RootCause AI Backend Master Prompt - Part 3

SECURITY

Implement production-grade security.

• Helmet
• CORS with allowed origins
• express-rate-limit
• HTTP-only JWT cookies
• Secure cookies in production
• bcrypt hashing (12 salt rounds)
• Express Validator
• MongoDB injection protection
• XSS sanitization
• Do not expose stack traces in production
• Validate every request
• Restrict upload MIME types
• Maximum upload size
• Authentication required for all analysis routes

ERROR HANDLING

Create AppError class.

Create global error middleware.

Return consistent JSON responses.

Log unexpected errors.

DATABASE BEST PRACTICES

Create indexes:

User
email (unique)

Analysis
userId
createdAt
severity

Always query analyses using both:
userId + analysisId

Never allow one user to access another user's analysis.

FILE HANDLING

Store uploads inside:

uploads/

Create subfolders:

bugReports/
logs/
stackTraces/
screenshots/
code/

Delete temporary extracted files after processing.

AI PROMPT BUILDER

Build one structured prompt using:

Bug Report

Console Logs

Stack Trace

Code Snippet

Environment

Return ONLY JSON.

Do not request markdown.

Do not request explanations outside JSON.

GEMINI RESPONSE FORMAT

```
{
summary:"",
reproductionSteps:[],
rootCause:[],
confidence:{
score:92,
level:"High"
},
suggestedFiles:[],
fixRecommendations:[],
severity:"High",
priority:"P1"
}
```

PDF EXPORT

Create backend endpoint:

GET /api/analysis/:id/export

Generate a PDF containing:

Uploaded files list

Bug Summary

Reproduction Steps

Root Cause

Confidence

Suggested Files

Fix Recommendations

Severity

Priority

Timestamp

LOGGING

Morgan for HTTP logs.

Create application logger utility.

Log:
Authentication
Uploads
Gemini requests
Gemini failures
Database errors

DEPLOYMENT READY

Environment-based configuration.

Never hardcode secrets.

Support deployment on Render, Railway or VPS.

Use NODE_ENV for production settings.